AI Prompt/Response Governance & Usage Monitoring — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview) 5

What you get . . . 5

What this delivers . . . 5

The deployment model . . . 6

Outcome . . . 6

1. Solution Overview — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview) 6

What this solution is . . . 6

What this monitors and governs (the two questions) . . . 6

Privacy-by-design and role separation (Communication Compliance is HR/privacy-sensitive) . . . 7

The scope of "outcomes" (what this solution does and does not decide) . . . 7

Naming convention (used in every doc and script) . . . 7

The standard deployment model . . . 8

2. Requirements Guide — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview) 8

2.1 AI-governance licensing (verify in your tenant) . . . 9

2.2 Least-privilege Purview roles with strict separation of duties . . . 9

2.3 Purview auditing (unified audit log) turned on . . . 9

2.4 Communication Compliance readiness (Copilot as a monitored source; privacy-by-design) . . . 9

2.5 DLP with a Microsoft 365 Copilot / AI location (verify in your tenant) . . . 10

2.6 DSPM for AI as the monitoring surface (verify in your tenant) . . . 10

2.7 In-scope AI apps and population . . . 10

2.8 Pilot ring and test/simulation discipline . . . 10

Global Requirements — Microsoft Purview Solutions 11

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 11

2. Purview roles (least-privilege) and portal access . . . 11

3. Security & Compliance PowerShell + Graph toolchain . . . 12

4. Data sources & scope in scope . . . 12

5. Compliance, records, privacy & legal stakeholders . . . 12

6. A pilot scope and change control . . . 12

3. Implementation Guide — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview) 13

Step 0 — Confirm scope, licensing, roles, auditing, and connections (Assess) . . . 13

Step 1 — Inventory existing AI-governance config (Assess) . . . 14

Step 2 — Baseline AI prompt/response usage (Assess / Monitor) . . . 14

Step 3 — Design the governance policy set with stakeholders (Design) . . . 14
Step 4 — Create the Communication-Compliance AI policy (Configure → Pilot, limited scope) . . . 15
Step 5 — Create the DLP-for-AI (Copilot) policy in test mode (Configure → Pilot) . . . 15
Step 6 — (Optional, verify) Stage the risky-AI-usage insider-risk signal (Configure) . . . 16
Step 7 — Validate the pilot (Validate) . . . 16
Step 8 — Expand and enforce (Expand) . . . 16
5. Testing Guide — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview) . . . 17
Test 1 — Environment, licensing, roles, and auditing . . . 17
Test 2 — Governance-config inventory is complete . . . 17
Test 3 — AI usage monitoring populates . . . 17
Test 4 — Privacy-by-design is in effect (Communication Compliance) . . . 17
Test 5 — Communication-Compliance AI policy is pilot-scoped only . . . 18
Test 6 — DLP-for-AI helper makes no change in dry-run . . . 18
Test 7 — DLP-for-AI policy is created in test mode only . . . 18
Test 8 — Pilot matches are acceptable (enforcement/expansion gate) . . . 18
Test 9 — Monitoring aligns with policy matches . . . 18
Test 10 — Validation evidence is captured . . . 18
Test 11 — Rollback works . . . 19
6. Troubleshooting Guide — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview) 19
Communication Compliance, DLP, or DSPM for AI blade is not visible . . . 19
`AIPROMPT-ScopeConfig.ps1` reports the session as FAIL . . . 19
AI usage monitoring is empty (`AIPROMPT-Monitor.ps1` returns nothing) . . . 19
`Search-UnifiedAuditLog` returns nothing or errors . . . 19
The Communication-Compliance policy can't target Copilot/AI interactions . . . 20
Reviewers can see real usernames (anonymization not working) . . . 20
`AIPROMPT-Configure-Governance.ps1 -Action DlpForAI` stops asking for `-DlpAiLocation` . . . 20
DLP-for-AI cmdlet fails as "not recognized" / access denied, or the Copilot location is rejected . . . 20
A DLP-for-AI policy landed in an enforcing state . . . 20
Too many false positives in the pilot . . . 21
Reviewers are overwhelmed after expanding scope . . . 21
Insider Risk "risky AI usage" is unavailable . . . 21
Escalation boundary . . . 21
7. Best Practices — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview) . . . 23
8. Deliverables Summary — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview) 23
Documentation . . . 23

PowerShell scripts 23
What the buyer receives 24
Outcome 25
Appendix A — PowerShell Scripts 26

Executive Summary — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview)

Sensitive data now flows into and out of AI. Employees paste confidential material into Microsoft 365 Copilot and other AI apps, and receive responses that surface sensitive content — and most organizations have **no visibility into what is in those prompts and responses, and no policy governing them**. That is both a compliance gap and a data-risk exposure. This solution closes it inside Microsoft Purview: it stands up **usage monitoring of AI prompts and responses** (what AI was used, by whom, and which interactions touched sensitive data) and the **policy that governs that content** — **Communication Compliance** scoped to AI/Copilot interactions and **DLP for Copilot/AI** — so sensitive data in AI is seen, evidenced, and governed.

This is a complete, deploy-it-today package written for a competent Purview / compliance administrator, using only the Microsoft Purview portal, Security & Compliance PowerShell, and Microsoft Graph — no third-party tooling. Because monitoring people's prompts is HR- and privacy-sensitive and policy changes are high-impact, every policy is built with **privacy-by-design (anonymization), strict role separation**, and is **piloted in a limited/test scope** before it is enforced or expanded.

What you get

- A plain-language Solution Overview of what this monitors and governs, the availability/licensing caveat for

these evolving AI-governance features, the privacy-by-design and role-separation posture, and the boundary between technical method and HR/legal determination.

- A Requirements Guide with verify / implement-if-missing for every prerequisite — licensing, least-privilege

roles with separation of duties, auditing, Communication Compliance readiness, the DLP Copilot location, DSPM for AI, in-scope AI apps/population, and pilot discipline.

- An Implementation Guide of precise, ordered portal and PowerShell steps: baseline AI usage, design the

policy set with stakeholders, create the Communication-Compliance AI policy (pilot-scoped, anonymized), create DLP for AI in test mode, optionally stage risky-AI-usage monitoring, validate, expand to enforce, and review on a recurring cadence.

- Five PowerShell scripts for scope/health checking, governance-config discovery, AI usage monitoring, safe

governance configuration (read-only or `-WhatIf` / test mode by default), and validation/evidence.

- Testing and Troubleshooting guides, with an explicit privacy gate and enforcement gate, for a confident,

safe rollout.

What this delivers

A monitored baseline of AI prompt/response usage, an evidence record of which interactions touch sensitive data, a Communication-Compliance policy detecting sensitive/risky AI content under anonymization, a DLP-for-AI policy keeping labeled content out of AI processing, and a validated rollout — piloted in a limited/test scope and expanded only after the gate passes — that governs AI content rather than merely observing it.

The deployment model

Assess → Design → Configure → Pilot (simulate/test) → Validate → Expand (enforce).

Outcome

AI prompt/response risk made visible and governed — usage monitored, sensitive interactions evidenced, and Communication-Compliance + DLP-for-AI policy piloted and enforced under privacy-by-design — so data in AI is defensible. Feature availability is flagged to verify in your tenant; HR, regulatory, records, and legal determinations remain with your governance functions.

1. Solution Overview — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview)

What this solution is

People now paste and receive sensitive data through AI — Microsoft 365 Copilot and other AI apps — and most organizations have **no visibility into what is in those prompts and responses** and **no policy governing them**. This solution closes that gap inside Microsoft Purview. It stands up **usage monitoring of AI prompts and responses** (what AI was used, by whom, and which interactions touched sensitive data) and the **policy that governs that content** — **Communication Compliance** scoped to AI/Copilot interactions and **Data Loss Prevention (DLP) for Copilot/AI** — so sensitive data flowing into and out of AI is *seen*, *evidenced*, and *governed*, not left blind.

This is a repeatable, self-guided way to **monitor AI prompt/response usage and wire the governing policy** using only the **Microsoft Purview portal** (`https://purview.microsoft.com`), **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party tooling. Because Communication Compliance and DLP changes are high-impact (and Communication Compliance is HR- and privacy-sensitive), **every policy is piloted in a limited/test/simulation scope first**, validated, and only then expanded.

What this monitors and governs (the two questions)

- **Usage monitoring — *what has AI touched?*** The prompt/response activity of Microsoft 365 Copilot and

other AI apps, sourced from **Purview auditing** (`CopilotInteraction` records) and the **DSPM for AI** interaction reports: who used AI, which app, and which prompts/responses referenced **sensitive data** (sensitivity-labeled or sensitive-information-type content). This is the evidence baseline.

- **Governing policy — *what happens when a prompt/response contains sensitive data?*** Two Purview levers:

• **Communication Compliance** — a policy that **detects sensitive or risky content in AI/Copilot prompts and responses** for review (data-leak / offensive-language / sensitive-info classifiers), routed to trained reviewers under strict role separation and privacy-by-design.

• **DLP for Microsoft 365 Copilot / AI** — a DLP policy whose **Copilot/AI location** keeps sensitivity-labeled content out of AI processing (or restricts it), so the most sensitive material is governed at the point AI would consume it.

• *(Optional, verify availability)* **Insider Risk Management** has a **risky-AI-usage** indicator/ template to surface anomalous AI use — referenced where licensed and in preview in your tenant.

> ***Feature availability & licensing — verify in your tenant.*** *AI-governance capabilities in Purview are **new and actively evolving**. Whether **Communication Compliance can monitor Copilot/AI interactions**, whether **DLP exposes a Microsoft 365 Copilot location**, whether **DSPM for AI** and the* `CopilotInteraction` *audit record are present, and whether each is included or needs **Microsoft 365 E5 / the E5 Compliance add-on** (and a **Microsoft 365 Copilot** license for AI activity to exist) **depend on your licensing and tenant**. Treat every blade, policy location, and record type named here as a current-state map to **confirm in your own portal**, never as guaranteed. This solution flags where to verify rather than asserting availability.*

Privacy-by-design and role separation (Communication Compliance is HR/privacy-sensitive)

Monitoring people's AI prompts and responses is **HR- and privacy-sensitive**. This solution builds the capability with:

• **Privacy-by-design / pseudonymization** — enable Communication Compliance **anonymization** so usernames are shown as system-generated aliases during review; only de-anonymize under a defined, approved process.

• **Strict role separation** — separate **Communication Compliance Administrators** (configure policy), **Analysts** (triage, pseudonymized), and **Investigators** (full detail, gated). No single person both configures and investigates.

• **Least data, defined retention** — scope policies to the in-scope population and purpose; do not over-collect.

The scope of "outcomes" (what this solution does and does not decide)

This solution delivers the **technical method and the evidence** — how to monitor AI prompt/response usage and configure the governing Communication-Compliance and DLP policy. It does **not** make **HR, regulatory, records, or legal determinations**: which AI usage is *acceptable*, what a policy match *means* for an individual, disciplinary or records/legal-hold actions on a Communication-Compliance case, and regulatory applicability are **deferred to your HR, compliance, privacy, and legal functions**. You provide the configuration and the evidence; they own the determination.

Naming convention (used in every doc and script)

Every artifact this solution creates or exports is named `<Purpose> – <Scope> – <Stage>` and reused verbatim across the docs, scripts, and portal so a reader can trace one artifact end to end.

Artifact	Name
AI usage / prompt-response monitoring export	`AI Usage – Copilot – Monitor`
Governance-config inventory export	`AI Governance Config – Estate – Discovery`
Sensitive AI-interaction report	`Sensitive AI Interactions – Estate – Assess`
Communication-compliance AI policy	`AI Interactions – Copilot – CommCompliance`
Pilot DLP-for-AI (Copilot) policy	`AI Prompt DLP – Copilot – Test`
Broad DLP-for-AI (Copilot) policy scope	`AI Prompt DLP – Copilot – Enforce`
Optional insider-risk AI-usage policy (preview)	`Risky AI Usage – Pilot – Monitor`
Pilot scope (ring of users)	`AI Governance – Pilot – Ring1`
Broad scope	`AI Governance – Broad – Stage2`
Validation evidence export	`AI Governance Validation – Estate – Evidence`
Recurring usage-review cadence tag	`AI Usage Review – Estate – Recurring`

The standard deployment model

> *Baseline AI usage and existing governance config → assess which prompts/responses touch sensitive data → design the Communication-Compliance + DLP-for-AI policy with privacy-by-design → pilot each policy in a **limited/test/simulation** scope → validate the matches and the evidence → **expand to enforce/broaden** → review AI usage on a recurring cadence. Pattern: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce).***

2. Requirements Guide — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview)

Verify **every** requirement before configuring. Each entry gives **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites (tenant compliance licensing, Purview roles, the S&C PowerShell + Graph toolchain, in-scope workloads, compliance/records/privacy/legal stakeholders, and pilot/change-control) are in `global-requirements-purview.md` — this guide adds the prerequisites specific to AI prompt/response governance and monitoring.

> ***Availability caveat.** AI-governance capabilities in Purview (Copilot monitoring in Communication Compliance, a DLP **Microsoft 365 Copilot** location, DSPM for AI, the `CopilotInteraction` audit record, risky-AI-usage insider-risk indicators) are **new, evolving, and licensing-/tenant-dependent**. Where this guide names a portal path, policy location, or record type, **confirm it exists in your tenant** — several requirements below are "verify in your tenant" by design.*

2.1 AI-governance licensing (verify in your tenant)

Description: The compliance licensing these capabilities require — commonly **Microsoft 365 E5** or the **E5 Compliance** add-on for **Communication Compliance**, **DLP for Copilot/AI**, and **DSPM for AI**; plus a **Microsoft 365 Copilot** (or other AI-app) license for AI prompt/response activity to *exist* and be monitorable. **Why:** Communication Compliance, advanced DLP, and DSPM for AI are plan-gated; with no Copilot/AI in use there is nothing to monitor yet. **Verify:** In the Microsoft 365 admin center confirm the subscriptions/add-ons; in the Purview portal confirm **Communication Compliance**, **Data Loss Prevention**, and **DSPM for AI** are visible. Run `AIPROMPT-ScopeConfig.ps1` (read-only) to enumerate the AI-governance features your session can see. **Implement:** Assign/purchase the required licensing before starting; if a capability is absent, note it out of scope and proceed with the licensed subset (e.g. usage monitoring only, no DLP-for-AI location yet).

2.2 Least-privilege Purview roles with strict separation of duties

Description: Membership in the least-privilege role groups these capabilities need, kept **separate**: **Communication Compliance Administrators** (configure policy), **Communication Compliance Analysts** (triage on pseudonymized data), **Communication Compliance Investigators** (full detail, gated), plus the **DLP / Information Protection** configuration role and an **Audit** reader role for monitoring. Confirm the **exact current role-group names** in your portal. **Why:** Purview uses fine-grained role groups; monitoring people's communications demands separation of duties so no one both configures policy and investigates individuals. **Verify:** Purview portal → **Settings / Roles & scopes** → **Role groups** — confirm each account's membership matches its function; confirm you can open **Communication Compliance** and **DLP** without an access error. **Implement:** Assign the least-privilege role groups under change control; reserve Global/Compliance Administrator for the initial enablement only. Document who holds Analyst vs Investigator rights.

2.3 Purview auditing (unified audit log) turned on

Description: Purview **Audit** (the unified audit log) enabled tenant-wide, because AI usage monitoring — prompt/response activity and DSPM-for-AI reporting — is sourced from audit records (e.g. the `CopilotInteraction` record type). **Why:** Without auditing on, the AI usage/monitoring signal and DSPM-for-AI reports are empty or incomplete. **Verify:** Purview portal → **Audit** shows searching is on; `AIPROMPT-ScopeConfig.ps1` reports whether `UnifiedAuditLogIngestionEnabled` is true. `CopilotInteraction` records should appear once Copilot/AI is used. **Implement:** Turn on auditing (a one-time tenant action); allow time for records to accumulate before expecting monitoring to populate.

2.4 Communication Compliance readiness (Copilot as a monitored source; privacy-by-design)

Description: Communication Compliance available and **enabled/onboarded**, with **anonymization (pseudonymization)** configured, trained reviewers assigned, and — **verify in your tenant** — the ability to include **Microsoft 365 Copilot / AI interactions** as a monitored source in a policy. **Why:** The governance layer for *risky/sensitive content inside prompts and responses* is a Communication Compliance policy; anonymization and reviewer training are prerequisites for running it lawfully and fairly. **Verify:** Purview portal → **Communication Compliance** loads; **Settings** → **Privacy** anonymization is available; confirm whether a policy can target Copilot/AI interactions (the template/source name evolves).

`AIPROMPT-Discovery.ps1` inventories existing Communication Compliance policies via `Get-SupervisoryReviewPolicyV2`. **Implement:** Onboard Communication Compliance, enable anonymization, assign Analysts/Investigators, and confirm the Copilot/AI monitored source is present before creating the AI policy — otherwise scope to the DLP-for-AI + monitoring path.

2.5 DLP with a Microsoft 365 Copilot / AI location (verify in your tenant)

Description: Data Loss Prevention available, and — **verify** — a **Microsoft 365 Copilot** (or AI) **location** exposed by DLP so a policy can govern how sensitivity-labeled content is processed by Copilot/AI. Requires a baseline of **sensitivity labels** and/or **sensitive information types** as the levers the policy matches on. **Why:** DLP for Copilot/AI is the preventive lever — it keeps the most sensitive (labeled) content out of AI processing. It has no effect without labels/SITs to match and the Copilot location to scope to. **Verify:** Purview portal → **Data Loss Prevention** → **Policies** → **Create** and confirm whether a **Copilot / AI** location is offered; **Information Protection** → **Labels** shows your taxonomy. `AIPROMPT-Discovery.ps1` inventories DLP policies, labels, and sensitive information types. **Implement:** Stand up a baseline label taxonomy (a dedicated sensitivity-labels solution covers this) and confirm the Copilot/AI DLP location; if the location is absent for your plan, use the portal's DSPM-for-AI one-click "protect sensitive data from Copilot" policy where present, or scope to monitoring + Communication Compliance only.

2.6 DSPM for AI as the monitoring surface (verify in your tenant)

Description: DSPM for AI visible and enabled, providing the **AI interaction reports** (sensitive interactions per AI app, data-access) that complement the scripted audit signal for usage monitoring. **Why:** DSPM for AI is the portal-native view of which prompts/responses touch sensitive data and which AI apps are in use — the monitoring dashboard this solution reads and evidences. **Verify:** Purview portal → **DSPM for AI** → **Reports** render; `AIPROMPT-Monitor.ps1` reports the scriptable audit signal that mirrors it. **Implement:** Complete the one-time DSPM-for-AI get-started/enablement (may enable AI-interaction audit collection — confirm it aligns with Requirement 2.3); if absent, rely on the scripted audit monitoring.

2.7 In-scope AI apps and population

Description: Clarity on **which AI is in scope** (Microsoft 365 Copilot, Copilot experiences, and/or other enterprise AI apps) and **which population** (users/groups) the governance and monitoring cover. **Why:** Policies and reports key off the AI apps present and the in-scope users; monitoring the wrong scope either misses activity or over-collects. **Verify:** Confirm Copilot/AI rollout and the target population with the owning team and stakeholders; `AIPROMPT-Monitor.ps1` shows which AI activity is visible. **Implement:** Define the in-scope AI apps and population with stakeholders before authoring policies; if Copilot is not yet deployed, use the pre-adoption window to stage monitoring and policy so governance is live on day one.

2.8 Pilot ring and test/simulation discipline

Description: A named **pilot ring** (`AI Governance – Pilot – Ring1`) and the intent to run every high-impact policy — Communication Compliance and DLP for AI — in a **limited scope / test / simulation** mode first (as the category model requires, GR §6), reviewed with HR/privacy/legal before any expansion. **Why:** A Communication Compliance policy applied broadly can over-collect on real people; a DLP-for-AI policy in enforce can block legitimate AI use. Piloting in a limited/test scope surfaces impact and false-positives before anyone is affected. **Verify:** Confirm the pilot ring, that DLP **test mode** and a limited

Communication-Compliance scope are available, and that a change window/approval (including HR/privacy sign-off) exists. **Implement:** Define the pilot ring and change-control path before enforcing anything; the scripts default to `-WhatIf` and create the DLP-for-AI policy in **test** mode.

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

- **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires (E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).
- **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the right plan.
- **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is visible in the Purview portal.
- **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

- **Description:** Access with the least-privilege **Purview / compliance role** the solution names (e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.
- **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.
- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

• **Why required:** Configuration, automation, and the provided scripts run through these.

• **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.

• **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

• **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

• **Why required:** Purview policies key off the in-scope workloads and the classification scheme.

• **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

• **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

• **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

• **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

• **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.

• **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

• **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview)

Follow these steps **in order**. Monitoring is read in the **Microsoft Purview portal** (`https://purview.microsoft.com`) and via Security & Compliance PowerShell (`Connect-IPPSSession`) / Exchange Online (`Connect-ExchangeOnline`, for `Search-UnifiedAuditLog`) / Microsoft Graph. Governance policy (Communication Compliance + DLP for AI) is created and piloted before it is expanded. Artifact names follow the `<Purpose> – <Scope> – <Stage>` convention from the Overview and are reused verbatim. **Every high-impact policy is piloted in a limited/test scope first** — the scripts default to `-WhatIf` and create DLP for AI in **test** mode.

> ***Model:*** *Baseline AI usage and governance config → assess sensitive prompts/responses → design the Communication-Compliance + DLP-for-AI policy with privacy-by-design → pilot each in a limited/test scope → validate → expand/enforce → recurring review. Pattern:* ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot (simulate/test)*** *→* ***Validate*** *→* ***Expand (enforce). Portal-path caveat.*** *The Copilot/AI monitoring source in Communication Compliance, the DLP* ***Copilot*** *location, and the DSPM-for-AI blades are evolving; paths below are the current map. If a blade, source, or policy location differs in your tenant, use the closest equivalent and* ***confirm before acting*** *— do not assume a path that is not present.* ***Privacy gate.*** *Communication Compliance monitors people's prompts and responses.* ***Enable anonymization first, keep Analyst/Investigator roles separate, and get HR/privacy/legal sign-off on the pilot before it runs.***

Step 0 — Confirm scope, licensing, roles, auditing, and connections (Assess)

1. Run `AIPROMPT-ScopeConfig.ps1` (read-only). It confirms your `Connect-IPPSSession` / `Connect-ExchangeOnline` / `Connect-MgGraph` sign-in, reports whether **auditing** is on (`UnifiedAuditLogIngestionEnabled`), and enumerates the AI-governance features present (Communication Compliance policies, DLP, sensitivity labels, DSPM-for-AI/Copilot audit signal) — resolving Requirements 2.1–2.6.

1. In the Purview portal confirm **Communication Compliance**, **Data Loss Prevention**, and **DSPM for AI** are visible (Requirements 2.4–2.6). Note any capability absent so you scope around it.

1. Confirm the **pilot ring** `AI Governance – Pilot – Ring1`, the change window, and **HR/privacy/legal

sign-off** (Requirement 2.8) before any configuration.

Pass/fail: Sign-in succeeds; auditing is on; Communication Compliance, DLP, and DSPM for AI are visible; pilot ring and privacy sign-off agreed. **Rollback:** None — read-only.

Step 1 — Inventory existing AI-governance config (Assess)

1. Run `AIPROMPT-Discovery.ps1` (read-only). It inventories **sensitivity labels**, **sensitive information

types**, DLP policies/rules **(flagging any already scoped to a Copilot/AI location), and existing** Communication Compliance policies** (`Get-SupervisoryReviewPolicyV2`), writing the export `AI Governance Config – Estate – Discovery`.

1. Review against Requirements 2.4–2.5 — this is your baseline of the levers (labels, SITs, DLP) the

governance policy will match on and confirms whether any AI governance already exists.

Pass/fail: The export lists your labels, SITs, DLP policies, and Communication Compliance policies. **Rollback:** None — read-only.

Step 2 — Baseline AI prompt/response usage (Assess / Monitor)

1. Run `AIPROMPT-Monitor.ps1` (read-only). It pulls `CopilotInteraction` (and any additional configured

AI record types) from the unified audit log for the window, summarizes **who used AI, which app, and which interactions referenced sensitive/labeled resources**, and writes `AI Usage – Copilot – Monitor` and `Sensitive AI Interactions – Estate – Assess`.

1. In the portal, open **DSPM for AI** → **Reports** and cross-read the **sensitive interactions per AI app**

view against the export. This is the evidence baseline of *what AI has actually touched*.

1. If the export is empty, confirm auditing is on (Requirement 2.3) and that Copilot/AI has been used — with

no AI activity there is nothing to monitor yet (pre-adoption; stage the policy so it is live on day one).

Pass/fail: `AI Usage – Copilot – Monitor` and `Sensitive AI Interactions – Estate – Assess` are written; you can name the AI apps in use and the interactions touching sensitive data. **Rollback:** None — read-only.

Step 3 — Design the governance policy set with stakeholders (Design)

1. With **HR, compliance, privacy, and legal** (GR §5), agree: which **sensitive information types /

sensitivity labels **define a governed prompt/response; whether the Communication-Compliance policy monitors for** sensitive-info / data-leak / offensive-language **classifiers; the** in-scope population**; the** anonymization **requirement; and what a DLP-for-AI policy should do with labeled content (audit vs restrict).** The determination is theirs**; you provide the technical method and will implement the agreed set.

1. Record the agreed policy definitions and the two artifact names to be created:

`AI Interactions – Copilot – CommCompliance` and `AI Prompt DLP – Copilot – Test`.

Pass/fail: Agreed policy definitions, in-scope population, classifiers, and anonymization recorded and signed off. **Rollback:** None — design only.

Step 4 — Create the Communication-Compliance AI policy (Configure → Pilot, limited scope)

1. **Privacy-by-design first.** Purview portal → **Communication Compliance** → **Settings** → **Privacy** — confirm

anonymization is **on** so reviewers see pseudonymized aliases.

1. **Communication Compliance** → **Policies** → **Create policy.** Create `AI Interactions – Copilot – CommCompliance`

scoped **only to the pilot ring** `AI Governance – Pilot – Ring1`, with **Microsoft 365 Copilot / AI interactions** as the monitored source (**verify this source exists in your tenant** — if absent, monitor via Step 2 audit signal only), the agreed classifiers/sensitive-info conditions, and the agreed reviewers.

1. `AIPROMPT-Configure-Governance.ps1 -Action CommComplianceReview` (read-only) prints the recommended

scope/reviewer/anonymization checklist to confirm the portal policy matches the Step 3 design. **The policy is created in the portal** (Communication Compliance policy creation is privacy-sensitive and its parameters vary — the script does not silently create it).

Pass/fail: `AI Interactions – Copilot – CommCompliance` exists, scoped to the pilot ring only, with anonymization on and reviewers assigned. **Rollback:** Delete the policy — it only routes matches to review, it changes no content.

Step 5 — Create the DLP-for-AI (Copilot) policy in test mode (Configure → Pilot)

1. Run `AIPROMPT-Configure-Governance.ps1 -Action DlpForAI -Scope "AI Governance – Pilot – Ring1"

-DlpAiLocation "<your-Copilot-location>" (defaults to -WhatIf; add -Commit to create it). With -Commit it creates the DLP policy AI Prompt DLP – Copilot – Test in test/disabled mode, scoped to the pilot ring, matching the agreed labels/SITs on the Copilot/AI location. The Copilot location name is licensing-dependent and evolving — the script requires you to pass it (-DlpAiLocation) and does not assume it.

1. If DLP does not expose a Copilot location in your tenant, use the portal's **DSPM for AI** one-click

"protect sensitive data from Copilot" policy where present, and record it under the same artifact name.

Pass/fail: `AI Prompt DLP – Copilot – Test` exists in **test** mode on the pilot ring; nothing is enforced. **Rollback:** Delete the test policy — it enforces nothing.

Step 6 — (Optional, verify) Stage the risky-AI-usage insider-risk signal (Configure)

1. **If Insider Risk Management and its risky-AI-usage template/indicators are available and licensed in your

tenant **(verify — this is preview and evolving), create** `Risky AI Usage – Pilot – Monitor` **scoped to the pilot ring in the portal, to surface anomalous AI use. Keep it in a** monitor/analytics** posture, not action. `AIPROMPT-Configure-Governance.ps1 -Action InsiderRiskCheck` (read-only) reports whether the insider-risk surface is present.

1. If unavailable, skip — the Communication-Compliance policy and monitoring cover the core scope.

Pass/fail: Either the monitor policy exists (pilot scope) or the capability is confirmed absent and noted. **Rollback:** Delete the policy — it only surfaces analytics.

Step 7 — Validate the pilot (Validate)

1. Run `AIPROMPT-Validate.ps1` (read-only). It confirms `AI Prompt DLP – Copilot – Test` is in **test** mode

(not enforcing), confirms `AI Interactions – Copilot – CommCompliance` exists and is scoped to the pilot ring, and re-checks that AI interactions are being captured — writing `AI Governance Validation – Estate – Evidence`.

1. In the portal, review **Communication Compliance** → **Policies** → the AI policy's **pending items** and the

DLP test matches for **false positives**, with the assigned (pseudonymized) reviewers. Confirm with HR/privacy that reviewer workflow and anonymization behave as designed.

1. Re-run `AIPROMPT-Monitor.ps1` and confirm the monitoring signal aligns with the policy matches (the

sensitive interactions being flagged are the ones the policy is meant to catch).

Pass/fail: DLP policy is in test, Communication-Compliance policy scoped to the pilot ring with anonymization working, matches reviewed with an acceptable false-positive rate, monitoring aligns. See Testing (doc 5) for the explicit gates. **Rollback:** Adjust conditions and re-validate; enforce/expand nothing until the gate passes.

Step 8 — Expand and enforce (Expand)

1. **Only after the pilot gate passes** and with change-control + HR/privacy/legal approval: widen the

Communication-Compliance policy scope from `AI Governance – Pilot – Ring1` to `AI Governance – Broad – Stage2`, and flip the **DLP-for-AI** policy from **test** to **enforce** — `AIPROMPT-Configure-Governance.ps1 -Action Enforce -Commit` performs the mode change on the named DLP policy (still gated behind `-Commit`), or expand in the portal.

1. Confirm reviewer capacity and retention settings scale to the broad population before widening

Communication Compliance.

1. Stand up the recurring review: tag the cadence `AI Usage Review – Estate – Recurring` and schedule the

read-only `ScopeConfig → Discovery → Monitor → Validate` chain (e.g. monthly) so AI usage and governance stay measured as adoption grows.

Pass/fail: DLP for AI enforced at broad scope, Communication-Compliance policy at broad scope with capacity confirmed, recurring review scheduled. **Rollback:** Return the DLP policy to **test** (or delete) and narrow the Communication-Compliance scope back to the pilot ring; the validation evidence export is the before-state to restore toward.

5. Testing Guide — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview)

Run these after each stage. Every test is safe (read-only, or DLP **test**-mode / limited-scope); the Communication-Compliance review and DLP test matches are the **gates** before any enforcement or scope expansion. Pass/fail is explicit.

Test 1 — Environment, licensing, roles, and auditing

Do: Run `AIPROMPT-ScopeConfig.ps1`; open **Communication Compliance**, **DLP**, and **DSPM for AI** in the Purview portal. **Expected:** Sign-in succeeds; auditing reports as **on** (`UnifiedAuditLogIngestionEnabled`); the three blades load without an access error; the AI-governance features are enumerated. Any absent capability is noted, not assumed. **Gate:** Do not proceed until auditing is on and the required blades are visible.

Test 2 — Governance-config inventory is complete

Do: Run `AIPROMPT-Discovery.ps1`; compare against **Information Protection** → **Labels**, **DLP** → **Policies**, and **Communication Compliance** → **Policies** in the portal. **Expected:** `AI Governance Config – Estate – Discovery` lists every sensitivity label, sensitive information type, DLP policy (flagging any Copilot/AI-scoped), and existing Communication-Compliance policy shown in the portal — the baseline of levers and existing governance.

Test 3 — AI usage monitoring populates

Do: Run `AIPROMPT-Monitor.ps1`; open **DSPM for AI** → **Reports**. **Expected:** `AI Usage – Copilot – Monitor` and `Sensitive AI Interactions – Estate – Assess` are written and list AI interactions (user, app, sensitive/labeled resources); the DSPM-for-AI sensitive-interactions report renders. *Note:* AI monitoring depends on auditing (Test 1) and on Copilot/AI having been used — empty results pre-adoption are expected.

Test 4 — Privacy-by-design is in effect (Communication Compliance)

Do: Purview portal → **Communication Compliance** → **Settings** → **Privacy**; open the AI policy's pending items as an **Analyst**. **Expected: Anonymization is on** — usernames display as system aliases to Analysts; only gated Investigators can de-anonymize. Analyst and Investigator roles are held by different accounts. **Gate:** Do not run the pilot on real people until anonymization is confirmed on and roles are

separated.

Test 5 — Communication-Compliance AI policy is pilot-scoped only

Do: Inspect `AI Interactions – Copilot – CommCompliance` in the portal; run `AIPROMPT-Configure-Governance.ps1 -Action CommComplianceReview` (read-only). **Expected:** The policy is scoped **only to** `AI Governance – Pilot – Ring1`, uses the agreed classifiers/sensitive-info conditions and the Copilot/AI monitored source (or is noted as audit-signal-only where the source is absent), with the assigned reviewers. The checklist output matches the design. **Gate:** If the policy is scoped broader than the pilot ring, narrow it before continuing.

Test 6 — DLP-for-AI helper makes no change in dry-run

Do: Run `AIPROMPT-Configure-Governance.ps1 -Action DlpForAI -DlpAiLocation "<loc>" -WhatIf`; then re-run `AIPROMPT-Discovery.ps1`. **Expected:** The dry-run prints the DLP policy it *would* create; the discovery inventory is unchanged — `-WhatIf` created nothing. **This is the gate that proves the helper is safe by default.**

Test 7 — DLP-for-AI policy is created in test mode only

Do: Run the helper with `-Commit` for the pilot (`AI Prompt DLP – Copilot – Test`); inspect it in the portal. **Expected:** The DLP policy is in **test/disabled** mode (enforces nothing), scoped to the pilot ring, on the **Copilot/AI location** you passed via `-DlpAiLocation`, matching the agreed labels/SITs. **Gate:** If it landed in an enforcing state, stop and correct before continuing.

Test 8 — Pilot matches are acceptable (enforcement/expansion gate)

Do: Let the pilot run the agreed window; review the Communication-Compliance **pending items** and the DLP **test** matches in the portal for false positives, with the pseudonymized reviewers; confirm with HR/privacy/legal. **Expected:** Flagged prompts/responses and DLP test matches align with intent, with an acceptable false-positive rate, and reviewer workflow behaves as designed with anonymization intact. **Gate: Do not enforce or expand (Step 8 of implementation) until this passes and HR/privacy/legal sign off.**

Test 9 — Monitoring aligns with policy matches

Do: Re-run `AIPROMPT-Monitor.ps1`; cross-read `Sensitive AI Interactions – Estate – Assess` with the policy's flagged items. **Expected:** The sensitive interactions surfaced by monitoring are the ones the policy is catching — evidence the monitoring and the governing policy are consistent, not divergent.

Test 10 — Validation evidence is captured

Do: Run `AIPROMPT-Validate.ps1`. **Expected:** `AI Governance Validation – Estate – Evidence` confirms the DLP policy is in **test** mode, the Communication-Compliance policy is pilot-scoped, and AI interactions are being captured — the defensible evidence record for the pilot.

Test 11 — Rollback works

Do: On the DLP-for-AI test policy, exercise the documented rollback (return to test / delete); narrow the Communication-Compliance scope back to the pilot ring. **Expected:** The DLP policy reverts with no residual content change; the Communication-Compliance scope narrows cleanly; the validation evidence export confirms the before-state is restorable.

6. Troubleshooting Guide — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview)

Field issues and fixes. Most stem from **licensing/availability** (these AI-governance features are new, evolving, and plan-gated), **auditing being off**, **Copilot/AI not having been used yet**, or a **privacy/role-separation** misconfiguration. When a portal path differs from this guide, confirm the current equivalent rather than assuming.

Communication Compliance, DLP, or DSPM for AI blade is not visible

- **Likely cause:** Licensing (Requirement 2.1) or role membership (Requirement 2.2).
- **Fix:** Confirm the subscription/add-ons in the M365 admin center; confirm your account is in the matching

role group in Purview → Roles & scopes. Run `AIPROMPT-ScopeConfig.ps1` to enumerate what your session can see. If the capability is genuinely absent for your plan, scope around it and note it.

`AIPROMPT-ScopeConfig.ps1` reports the session as FAIL

- **Cause:** Not connected to Security & Compliance PowerShell / Exchange Online.
- **Fix:** `Connect-IPPSSession` (for policy cmdlets) and `Connect-ExchangeOnline` (for

`Search-UnifiedAuditLog` and the audit-config check) with a modern-auth/MFA admin (GR §3). For Graph checks, `Connect-MgGraph`. Re-run.

AI usage monitoring is empty (`AIPROMPT-Monitor.ps1` returns nothing)

- **Cause 1 — auditing off:** AI prompt/response monitoring is sourced from the unified audit log. **Fix:**

Turn auditing on (Requirement 2.3); `AIPROMPT-ScopeConfig.ps1` shows `UnifiedAuditLogIngestionEnabled`. Allow time for records to accumulate.

- **Cause 2 — no AI usage yet:** With no Copilot/AI activity there is nothing to monitor. **Fix:** Expected

pre-adoption — stage the policy so governance is live once Copilot is enabled.

- **Cause 3 — wrong audit RecordType:** The record type/operations that surface AI interactions evolve

(e.g. `CopilotInteraction`). **Fix:** Confirm the current value in Purview → Audit and pass it via `-AiRecordTypes`.

`Search-UnifiedAuditLog` returns nothing or errors

- **Cause:** Not connected to Exchange Online, auditing off, or the window predates auditing being on.

• **Fix:** `Connect-ExchangeOnline`; confirm auditing on; widen `-Days` within the retained window. Audit

data has ingestion latency — very recent activity may not appear yet.

The Communication-Compliance policy can't target Copilot/AI interactions

• **Cause:** The Copilot/AI monitored source is not present in your tenant (licensing/rollout) — this is a

new, evolving capability.

• **Fix:** Confirm availability in Purview → Communication Compliance when creating the policy. If the source

is absent, monitor AI prompt/response activity via the audit signal (`AIPROMPT-Monitor.ps1`) and govern the content with DLP for AI; add the Communication-Compliance source when it becomes available. **Verify in your tenant** — do not assume the source exists.

Reviewers can see real usernames (anonymization not working)

• **Cause:** Anonymization is off, or the reviewer holds an Investigator (de-anonymized) role.

• **Fix:** Purview → Communication Compliance → **Settings** → **Privacy** — turn **anonymization on**

(Requirement 2.4). Confirm Analysts hold the pseudonymized role and only gated Investigators can de-anonymize (Requirement 2.2). **This is a privacy gate — do not run the pilot on real people until it is correct.**

`AIPROMPT-Configure-Governance.ps1 -Action DlpForAI` stops asking for `-DlpAiLocation`

• **This is intentional.** The DLP location that scopes a policy to Microsoft 365 Copilot / AI is

licensing-dependent and evolving, so the script will not assume it. **Fix:** Confirm the exact location name in Purview → DLP (or use the DSPM-for-AI one-click "protect sensitive data from Copilot" policy in the portal if present), then pass it via `-DlpAiLocation`.

DLP-for-AI cmdlet fails as "not recognized" / access denied, or the Copilot location is rejected

• **Cause:** Advanced DLP or the Copilot location is unlicensed/absent, or the role lacks configuration

rights.

• **Fix:** Confirm licensing (Requirement 2.1) and the DLP configuration role (Requirement 2.2). If the

Copilot location is not offered, use the portal DSPM-for-AI one-click policy where present, or scope to monitoring + Communication Compliance only. `AIPROMPT-Discovery.ps1` warns where a feature isn't readable.

A DLP-for-AI policy landed in an enforcing state

• **Cause:** Wrong mode or a manual portal change.

- **Fix:** `AIPROMPT-Configure-Governance.ps1 -Action DlpForAI` creates the DLP policy in **test** mode by

design. If a policy is enforcing before the gate, return it to test (`Set-DlpCompliancePolicy -Mode TestWithoutNotifications`) and re-validate. Never enforce before Testing Test 8 passes and HR/privacy/legal sign off.

Too many false positives in the pilot

- **Cause:** Conditions too broad (sensitive-info-type confidence, label scope, classifier sensitivity).
- **Fix:** Tighten the Communication-Compliance conditions and/or the DLP rule and **re-run the pilot** — do

not enforce or expand. The whole point of the limited/test pilot is to tune before anyone is affected.

Reviewers are overwhelmed after expanding scope

- **Cause:** Match volume at broad scope exceeds reviewer capacity.
- **Fix:** Narrow the Communication-Compliance conditions, confirm reviewer capacity before widening

(Best Practices), and expand in stages (`AI Governance – Pilot – Ring1` → `AI Governance – Broad – Stage2`).

Insider Risk "risky AI usage" is unavailable

- **Cause:** The risky-AI-usage template/indicators are preview and licensing-dependent.
- **Fix:** This step is optional (Implementation Step 6). Confirm availability with

`AIPROMPT-Configure-Governance.ps1 -Action InsiderRiskCheck`; if absent, the Communication-Compliance policy and monitoring cover the core scope. **Verify in your tenant** — do not assume the template exists.

Escalation boundary

HR, regulatory, records-retention, and legal questions — whether a given AI usage is *acceptable*, what a policy match *means* for an individual, disciplinary action, and records/legal-hold implications — are **not** resolved here. Capture the technical evidence (the monitoring and validation exports) and route the determination to your HR, compliance, privacy, and legal functions (GR §5).

7. Best Practices — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview)

- **Monitor before you govern.** Baseline what AI is actually used for and which prompts/responses touch

sensitive data *first* (Step 2). Governance aimed at real usage is proportionate; governance aimed at assumptions over- or under-shoots.

- **Privacy-by-design is non-negotiable.** Turn on Communication Compliance **anonymization** so reviewers

see pseudonymized aliases, and only de-anonymize through a defined, approved process. Monitoring people's prompts is HR/privacy-sensitive — build it to be fair and defensible from day one.

- **Separate the duties.** Keep **Communication Compliance Administrators** (configure), **Analysts**

(triage on pseudonymized data), and **Investigators** (full detail, gated) as different people. No one should both write the policy and investigate individuals.

- **Always pilot in a limited/test scope.** Create the Communication-Compliance policy scoped to the pilot

ring only, and the DLP-for-AI policy in **test** mode — `-WhatIf` is the default on the configuration helper for the same reason. Read every intended action before `-Commit`, and enforce/expand only after the gate passes with HR/privacy/legal sign-off.

- **Let HR/compliance/privacy/legal own the determination.** You provide the technical method and the

evidence; *whether* a prompt is acceptable, what a match *means* for an individual, and any disciplinary, records, or legal-hold action are their calls. Capture the agreed policy definition before configuring.

- **Verify availability, never assume it.** Copilot monitoring in Communication Compliance, the DLP

Copilot location, DSPM for AI, the `CopilotInteraction` record, and risky-AI-usage insider-risk indicators are new and evolving. When a source, location, or blade isn't where this guide says, confirm it in your tenant and use the closest current equivalent — don't force a path that isn't there.

- **Confirm the Copilot/AI DLP location before you enforce.** The location name that scopes DLP to Copilot

is licensing-dependent and evolving; the configuration helper parameterizes it (`-DlpAiLocation`) rather than assuming it. Verify the exact location so the policy governs where you intend.

- **Keep auditing on.** AI usage monitoring is only as complete as the unified audit log feeding it. If

monitoring looks empty, check auditing is on and that Copilot/AI has actually been used, and allow for audit ingestion latency.

- **Labels and sensitive information types are the levers — keep them healthy.** Both the

Communication-Compliance conditions and the DLP-for-AI policy match on your classification. A thin taxonomy caps how precisely you can govern prompts and responses; invest there.

- **Right-size reviewer capacity before broadening.** A policy that over-collects buries reviewers and

erodes the program. Tune conditions in the pilot so the broad-scope match volume is reviewable, and confirm capacity before expanding Communication Compliance.

- **Make usage review recurring.** AI adoption and the sensitivity of what people ask it drift. Schedule the

read-only `ScopeConfig → Discovery → Monitor → Validate` chain under `AI Usage Review – Estate – Recurring` so governance stays measured, not measured once.

• **Keep an easy rollback.** Every enforced DLP-for-AI policy should be one change from returning to test,

and the Communication-Compliance scope one change from returning to the pilot ring. Keep the validation evidence export as the before-state so any expansion can be safely reverted.

8. Deliverables Summary — AI Prompt/Response Governance & Usage Monitoring (Microsoft Purview)

Documentation

Document	Purpose
Executive Summary	Business case and what's in the box
1. Solution Overview	What this monitors (AI prompt/response usage, sensitive interactions) and governs (Communication Compliance for AI, DLP for Copilot/AI), the availability/licensing caveat, privacy-by-design & role separation, the outcome-vs-determination boundary, and the naming convention
2. Requirements Guide	Every AI-governance prerequisite with Verify / Implement-if-missing (licensing, least-privilege roles with separation of duties, auditing, Communication Compliance readiness, DLP Copilot location, DSPM for AI, in-scope AI apps/population, pilot discipline)
Global Requirements (Purview)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered portal + PowerShell steps: confirm scope, inventory governance config, baseline AI usage, design the policy set, create the Communication-Compliance AI policy (pilot scope, anonymized), create DLP for AI in test, optionally stage risky-AI-usage, validate, expand/enforce, recurring review
5. Testing Guide	Validation procedures with explicit pass/fail, the privacy gate, and the enforcement/expansion gate
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations for monitoring and governing AI prompts/responses safely

PowerShell scripts

All are safe-by-default (read-only, or `-WhatIf` / DLP **test** mode unless `-Commit`), use `Connect-IPPSSession` / `Connect-ExchangeOnline` and/or `Connect-MgGraph`, and store **no**

credentials.

Script	What it does
`AIPROMPT-ScopeConfig.ps1`	Read-only scope/health helper: confirms sign-in, reports whether **auditing** is on, and enumerates the AI-governance features present (Communication Compliance policies, DLP, sensitivity labels, Copilot audit signal). Resolves Requirements 2.1–2.6
`AIPROMPT-Discovery.ps1`	Read-only inventory of sensitivity labels, sensitive information types, DLP policies/rules (flagging Copilot/AI-scoped), and existing Communication Compliance policies. Writes `AI Governance Config – Estate – Discovery`
`AIPROMPT-Monitor.ps1`	Read-only AI usage/prompt-response monitoring report from Purview auditing (`CopilotInteraction` + configured AI record types): who used AI, which app, which interactions touched sensitive/labeled resources. Writes `AI Usage – Copilot – Monitor` and `Sensitive AI Interactions – Estate – Assess`
`AIPROMPT-Configure-Governance.ps1`	Governance configuration/remediation helper (DLP-for-AI / Communication-Compliance checklist / insider-risk check / enforce). Defaults to `-WhatIf`; with `-Commit` creates `AI Prompt DLP – Copilot – Test` in **test** mode on the parameterized Copilot location; outputs the Communication-Compliance scope/reviewer/anonymization checklist (does not silently create the privacy-sensitive policy); and (Enforce) flips the named DLP policy from test to on — never silently
`AIPROMPT-Validate.ps1`	Read-only validation/evidence: confirms the DLP-for-AI policy is in **test** mode, the Communication-Compliance policy is pilot-scoped, and AI interactions are being captured. Writes `AI Governance Validation – Estate – Evidence`

What the buyer receives

- This implementation guide as a **Word** document and **PDF**.
- All five **PowerShell scripts** in a single ZIP.
- A repeatable process following the model: **Assess → Design → Configure → Pilot (simulate/test) → Validate → Expand (enforce).**

Outcome

AI prompt/response risk made **visible and governed**: usage monitored across the estate with evidence of which prompts/responses touch sensitive data, a Communication-Compliance policy detecting sensitive/risky AI content under privacy-by-design and strict role separation, and DLP for Copilot/AI keeping the most sensitive material out of AI processing — every high-impact policy piloted in a limited/test scope before enforcement. HR, regulatory, records, and legal determinations remain with the organization's governance functions; this solution delivers the technical method and the evidence.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

AIPROMPT-Configure-Governance.ps1

Purpose: The configuration/remediation helper. Creates a DLP-for-AI (Copilot) policy in TEST mode, prints the Communication-Compliance scope/reviewer/anonymization checklist to build in the portal (privacy- sensitive — NOT auto-created), checks the insider-risk risky-AI-usage surface, and (Enforce) flips the named DLP policy from test to on. Defaults to -WhatIf; writes require -Commit. HOW TO RUN PowerShell 5.1+ or 7+ with Security & Compliance PowerShell: Connect-IPPSSession .\AIPROMPT-Configure-Governance.ps1 -Action DlpForAI -DlpAiLocation "<your-Copilot-location>" -WhatIf .\AIPROMPT-Configure-Governance.ps1 -Action DlpForAI -DlpAiLocation "<your-Copilot-location>" -Commit .\AIPROMPT-Configure-Governance.ps1 -Action CommComplianceReview # read-only checklist .\AIPROMPT-Configure-Governance.ps1 -Action InsiderRiskCheck # read-only .\AIPROMPT-Configure-Governance.ps1 -Action Enforce -Commit # test -> on EXPECTED RESULTS DlpForAI (dry-run): prints the policy it WOULD create, changes nothing. With -Commit: creates "AI Prompt DLP - Copilot - Test" in TEST mode. Enforce: sets that policy Mode to Enable. Neither the Communication-Compliance policy nor any content is silently changed. .NOTES White-label Microsoft Purview tooling. Safe-by-default. No credentials stored. VERIFY IN YOUR TENANT: the DLP location that scopes a policy to Microsoft 365 Copilot/AI is licensing- dependent and evolving — this script REQUIRES -DlpAiLocation and never assumes it. Communication Compliance policy creation is privacy-sensitive and its parameters vary; this script prints a checklist to build it in the portal rather than creating it. > [CmdletBinding()] param([ValidateSet("DlpForAI","CommComplianceReview","InsiderRiskCheck","Enforce")] [string]$Action = "CommComplianceReview", [string]$PolicyName = "AI Prompt DLP - Copilot - Test", [string]$Scope = "AI Governance - Pilot - Ring1", [string]$DlpAiLocation, # REQUIRED for DlpForAI/Enforce — never assumed [string[]]$SensitiveInfoTypes = @("Credit Card Number","U.S. Social Security Number (SSN)"), [switch]$Commit, [switch]$WhatIf)

How to run: PowerShell 5.1+ or 7+ with Security & Compliance PowerShell: Connect-IPPSSession .\AIPROMPT-Configure-Governance.ps1 -Action DlpForAI -DlpAiLocation "<your-Copilot-location>" -WhatIf .\AIPROMPT-Configure-Governance.ps1 -Action DlpForAI -DlpAiLocation "<your-Copilot-location>" -Commit .\AIPROMPT-Configure-Governance.ps1 -Action CommComplianceReview # read-only checklist .\AIPROMPT-Configure-Governance.ps1 -Action InsiderRiskCheck # read-only .\AIPROMPT-Configure-Governance.ps1 -Action Enforce -Commit # test -> on EXPECTED RESULTS DlpForAI (dry-run): prints the policy it WOULD create, changes nothing. With -Commit: creates "AI Prompt DLP - Copilot - Test" in TEST mode. Enforce: sets that policy Mode to Enable. Neither the Communication-Compliance policy nor any content is silently changed. .NOTES White-label Microsoft Purview tooling. Safe-by-default. No credentials stored. VERIFY IN YOUR TENANT: the DLP location that scopes a policy to Microsoft 365 Copilot/AI is licensing- dependent and evolving — this script REQUIRES -DlpAiLocation and never assumes it. Communication Compliance policy creation is privacy-sensitive and its parameters vary; this script prints a checklist to build it in the portal rather than creating it. > [CmdletBinding()] param([ValidateSet("DlpForAI","CommComplianceReview","InsiderRiskCheck","Enforce")] [string]$Action = "CommComplianceReview", [string]$PolicyName = "AI Prompt DLP - Copilot - Test", [string]$Scope = "AI Governance - Pilot - Ring1", [string]$DlpAiLocation, # REQUIRED for DlpForAI/Enforce — never assumed [string[]]$SensitiveInfoTypes = @("Credit Card Number","U.S. Social Security Number (SSN)"),

[switch]$Commit, [switch]$WhatIf)

AIPROMPT-Discovery.ps1

Purpose: Inventories the classification levers (sensitivity labels, sensitive information types), the DLP policies/rules (flagging any already scoped to a Copilot/AI location), and existing Communication Compliance policies — the baseline the AI governance policy will build on. Read-only. HOW TO RUN PowerShell 5.1+ or 7+ with Security & Compliance PowerShell: Connect-IPPSSession .\AIPROMPT-Discovery.ps1 EXPECTED RESULTS AI-Governance-Config-Estate-Discovery.csv listing labels, SITs, DLP policies/rules, and Communication Compliance policies. A thin taxonomy or no Copilot-scoped DLP is itself the first finding. .NOTES White-label Microsoft Purview tooling. Read-only. No credentials stored. VERIFY IN YOUR TENANT: a "Copilot/AI location" on a DLP policy is detected heuristically here (locations surfaced by the cmdlet evolve); confirm the actual Copilot location in Purview -> DLP. > [CmdletBinding()] param([string]$OutPath = ".\AI-Governance-Config-Estate-Discovery.csv")

How to run: PowerShell 5.1+ or 7+ with Security & Compliance PowerShell: Connect-IPPSSession .\AIPROMPT-Discovery.ps1 EXPECTED RESULTS AI-Governance-Config-Estate-Discovery.csv listing labels, SITs, DLP policies/rules, and Communication Compliance policies. A thin taxonomy or no Copilot-scoped DLP is itself the first finding. .NOTES White-label Microsoft Purview tooling. Read-only. No credentials stored. VERIFY IN YOUR TENANT: a "Copilot/AI location" on a DLP policy is detected heuristically here (locations surfaced by the cmdlet evolve); confirm the actual Copilot location in Purview -> DLP. > [CmdletBinding()] param([string]$OutPath = ".\AI-Governance-Config-Estate-Discovery.csv")

AIPROMPT-Monitor.ps1

Purpose: The AI usage monitoring report. Pulls AI/Copilot interaction records from Purview auditing (CopilotInteraction, the same signal that feeds DSPM for AI): who used AI, which app, and which prompts/responses referenced sensitive/labeled resources. Read-only evidence baseline. HOW TO RUN PowerShell 5.1+ or 7+ with Exchange Online / Security & Compliance PowerShell (Search-UnifiedAuditLog): Connect-ExchangeOnline .\AIPROMPT-Monitor.ps1 -Days 30 EXPECTED RESULTS AI-Usage-Copilot-Monitor.csv (all AI interactions) and Sensitive-AI-Interactions-Estate-Assess.csv (only interactions touching labeled/sensitive resources). Empty results usually mean auditing is off (Req 2.3) or Copilot/AI has not been used yet — confirm both. .NOTES White-label Microsoft Purview tooling. Read-only. No credentials stored. VERIFY IN YOUR TENANT: the audit RecordType that surfaces AI interactions evolves. This script parameterizes it (-AiRecordTypes, default CopilotInteraction); confirm the exact value in Purview -> Audit. For the richest view use the DSPM for AI reports in the portal — this script provides the portable, scriptable signal, not a replacement for that blade. > [CmdletBinding()] param([int]$Days = 30, [string[]]$AiRecordTypes = @("CopilotInteraction"), [int]$ResultSize = 5000, [string]$UsageOutPath = ".\AI-Usage-Copilot-Monitor.csv", [string]$SensitiveOutPath = ".\Sensitive-AI-Interactions-Estate-Assess.csv")

How to run: PowerShell 5.1+ or 7+ with Exchange Online / Security & Compliance PowerShell (Search-UnifiedAuditLog): Connect-ExchangeOnline .\AIPROMPT-Monitor.ps1 -Days 30 EXPECTED RESULTS AI-Usage-Copilot-Monitor.csv (all AI interactions) and Sensitive-AI-Interactions-Estate-Assess.csv (only interactions touching labeled/sensitive resources). Empty results usually mean auditing is off (Req 2.3) or Copilot/AI has not been used yet — confirm both. .NOTES White-label Microsoft Purview tooling. Read-only. No credentials stored. VERIFY IN YOUR TENANT: the audit RecordType that surfaces AI interactions evolves. This script parameterizes it

(-AiRecordTypes, default CopilotInteraction); confirm the exact value in Purview -> Audit. For the richest view use the DSPM for AI reports in the portal — this script provides the portable, scriptable signal, not a replacement for that blade. > [CmdletBinding()] param([int]$Days = 30, [string[]]$AiRecordTypes = @("CopilotInteraction"), [int]$ResultSize = 5000, [string]$UsageOutPath = ".\AI-Usage-Copilot-Monitor.csv", [string]$SensitiveOutPath = ".\Sensitive-AI-Interactions-Estate-Assess.csv")

AIPROMPT-ScopeConfig.ps1

Purpose: Confirms the toolchain sign-in, reports whether unified auditing is ON (the source of AI usage monitoring), and enumerates the AI-governance features present in the tenant — Communication Compliance policies, DLP policies, sensitivity labels, and the Copilot/AI audit signal — so you know what is licensed/available before configuring. Resolves Requirements 2.1-2.6. Read-only. HOW TO RUN PowerShell 5.1+ or 7+ with Exchange Online / Security & Compliance PowerShell (and optionally Graph): Connect-ExchangeOnline Connect-IPPSSession Connect-MgGraph -Scopes "AuditLog.Read.All" # optional .\AIPROMPT-ScopeConfig.ps1 EXPECTED RESULTS A PASS/FAIL health line per check. PASS = session connected, auditing on, and the AI-governance surfaces enumerated. FAIL on auditing means monitoring will be empty (turn auditing on, Req 2.3). .NOTES White-label Microsoft Purview tooling. Read-only. No credentials stored. VERIFY IN YOUR TENANT: Copilot monitoring in Communication Compliance, a DLP Copilot location, DSPM for AI, and the CopilotInteraction audit record are new/evolving and licensing-dependent. This script reports what your session can see; it does not assert availability. > [CmdletBinding()] param([int]$SampleDays = 7, [string[]]$AiRecordTypes = @("CopilotInteraction"))

How to run: PowerShell 5.1+ or 7+ with Exchange Online / Security & Compliance PowerShell (and optionally Graph): Connect-ExchangeOnline Connect-IPPSSession Connect-MgGraph -Scopes "AuditLog.Read.All" # optional .\AIPROMPT-ScopeConfig.ps1 EXPECTED RESULTS A PASS/FAIL health line per check. PASS = session connected, auditing on, and the AI-governance surfaces enumerated. FAIL on auditing means monitoring will be empty (turn auditing on, Req 2.3). .NOTES White-label Microsoft Purview tooling. Read-only. No credentials stored. VERIFY IN YOUR TENANT: Copilot monitoring in Communication Compliance, a DLP Copilot location, DSPM for AI, and the CopilotInteraction audit record are new/evolving and licensing-dependent. This script reports what your session can see; it does not assert availability. > [CmdletBinding()] param([int]$SampleDays = 7, [string[]]$AiRecordTypes = @("CopilotInteraction"))

AIPROMPT-Validate.ps1

Purpose: Confirms the pilot is safe and captured: the DLP-for-AI policy is in TEST mode (not enforcing), the Communication-Compliance AI policy exists and is pilot-scoped, and AI interactions are being captured by monitoring. Writes a defensible evidence record. Read-only. HOW TO RUN PowerShell 5.1+ or 7+ with Security & Compliance PowerShell (+ Exchange Online for the audit check): Connect-IPPSSession Connect-ExchangeOnline .\AIPROMPT-Validate.ps1 EXPECTED RESULTS AI-Governance-Validation-Estate-Evidence.csv with a PASS/FAIL per check. The gate before enforce/expand is: DLP policy in TEST, Communication-Compliance policy present + pilot-scoped, monitoring capturing AI. .NOTES White-label Microsoft Purview tooling. Read-only. No credentials stored. VERIFY IN YOUR TENANT: scope-name matching is heuristic (checks the policy name/comment for the pilot ring string). Confirm the actual assigned scope in the portal — the script evidences, it does not certify. > [CmdletBinding()] param([string]$DlpPolicyName = "AI Prompt DLP - Copilot - Test", [string]$CommCompliancePolicyName = "AI Interactions - Copilot - CommCompliance", [string]$PilotScope = "AI Governance - Pilot - Ring1", [string[]]$AiRecordTypes = @("CopilotInteraction"),

[int]$SampleDays = 14, [string]$OutPath = ".\AI-Governance-Validation-Estate-Evidence.csv")

How to run: PowerShell 5.1+ or 7+ with Security & Compliance PowerShell (+ Exchange Online for the audit check): Connect-IPPSSession Connect-ExchangeOnline .\AIPROMPT-Validate.ps1 EXPECTED RESULTS AI-Governance-Validation-Estate-Evidence.csv with a PASS/FAIL per check. The gate before enforce/expand is: DLP policy in TEST, Communication-Compliance policy present + pilot-scoped, monitoring capturing AI. .NOTES White-label Microsoft Purview tooling. Read-only. No credentials stored. VERIFY IN YOUR TENANT: scope-name matching is heuristic (checks the policy name/comment for the pilot ring string). Confirm the actual assigned scope in the portal — the script evidences, it does not certify. > [CmdletBinding()] param([string]$DlpPolicyName = "AI Prompt DLP - Copilot - Test", [string]$CommCompliancePolicyName = "AI Interactions - Copilot - CommCompliance", [string]$PilotScope = "AI Governance - Pilot - Ring1", [string[]]$AiRecordTypes = @("CopilotInteraction"), [int]$SampleDays = 14, [string]$OutPath = ".\AI-Governance-Validation-Estate-Evidence.csv")